8/28/2024

Research Report

Purchasing shares with Sharesies



Zane Grose
MEDIA DESIGN SCHOOL

Table of Contents

Introduction 2
Discussion 2
Network Diagram: 2
Data Flow – Purchasing out-of-country Shares: 3
End-to-end data communications: 4
What protocols are used? 4
Recommendations: 5
Conclusion 6
References 7

Introduction

Sharesies' is a New Zealand-based wealth platform that aims to bring financial empowerment to everyone. Their goal is to provide everyone with the same investment opportunities, whether a person has $0.05 or $500,000. They have two companies, Sharesies Limited (referred as the 'Platform Network') and Sharesies Nominee Limited (referred as 'Nominee Network'), and utilize Amazon Web Servers (AWS) for their data storage service.

Users use Sharesies for their investing needs, this requires Sharesies to hold a user's personally identifiable information (PII) and assets. A users money is held through the users trust through Sharesies Nominee Ltd, which naturally requires Sharesies to have a secure system, transparent communication, and trustworthy reputation.

In the body of this report, I will discuss the data trail through the Sharesies network and their third parties. You will find a network diagram of what I believe the Sharesies Limited and Sharesies Nominee Limited networks look like, a description of a user's data trail through their network and to the third-party brokerages.

Discussion

Network Diagram:

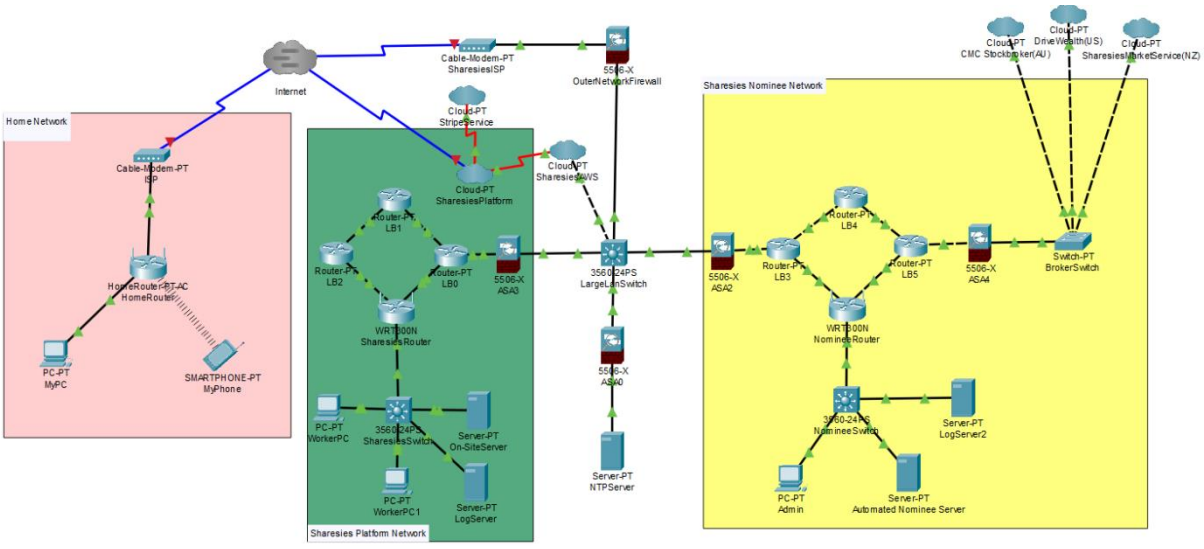


Figure 1: Assumed Sharesies network, including the Sharesies Platform, Sharesies Nominee Ltd, and home networks

Sharesies operates two distinct networks (Sharesies Ltd and Sharesies Nominee Ltd), these two networks are assumed to be connected in the same building. The switch connecting the networks handles what data is sent to each network, from AWS and the internet. This network diagram (*see Figure 1*) is designed to represent the architecture of the Sharesies network. Sharesies specifies that the Nominee and Platform networks are separated for enhanced security, reduced risk of attacks and isolates critical assets (Sharesies Help, 2024).

Sharesies Platform Network:

Devices on this network consist of the worker PCs and an assumed on-site server. These end devices are connected to an internal switch, connected to load-balancing routers and an internal firewall. This on-site server would be necessary for secure testing environments and having backups in event of outages or a disaster. The load balancing routers are crucial for uptime and robustness, critical when handling sensitive data.

Sharesies Nominee Network:

The nominee network has an admin computer and an assumed automated server, where the admin PC is to manage the server and investigate network traffic. These devices are connected to a switch. This switch is connected to load-balancing routers, where another switch sits, to determine what brokerage the automated server is attempting to communicate with. Finally, the load-balancing routers are connected to an internal firewall from the main switch.

Home Network:

This network represents a simple home network, which consists of common personal devices like a PC and phone connected to a router, further connected to the ISP modem to provide internet connection. A user will typically use their home network to access the hosted Sharesies platform and websites through the internet using domain name system resolution.

Data Flow – Purchasing out-of-country Shares:

Account Creation:

Initially users' information is entered on a personal device by using the Sharesies platform through application (mobile phone) or website (PC through web browser). The information travels through the internal channels to be stored in Sharesies' AWS.

Adding Funds:

After an account has been created, the user must add money into their account to place an order. This is done either by direct bank transfer or using Sharesies third-party payment service Stripe. Bank transfer is done through reference numbers that are unique to the users account which are entered when making a payment through your banking service. If using Stripe, the user would enter their card details and amount of money wanting to put into their account, this encrypted data would travel through secure channels in the Sharesies platform to the Stripe service, where Stripe would confirm payment with the bank using card details given in the payment process.

Placing an order:

After money has been added, the money is static until the user requests a purchase, withdrawal, or transfer. When a purchase for shares is request, the users money and PII is assumed to be handled automatically by a server connected to the Nominee network, pre-configured to follow compliance, regulations, and security requirements, authorized to create orders on behalf of Sharesies Nominee Ltd.

Confirmation & settlement of order:

It's assumed that the Nominee automated transaction server handles communications when an order has been placed, common in modern financial systems and briefly explained in (Bernstein & Newcomer, 2009). After placing the order, Sharesies will queue the order, then the automated server will communicate with the relevant third party and see if the market is open. If true, the third party (DriveWealth for US, CMC Brokers for AU) will queue your order till the market is open, then create that order using Sharesies' Nominee Ltd name, on the users behalf. DriveWealth does not require your PII, as the order is placed under Sharesies Nominee, and Sharesies handles all your PII on your behalf. (Sharesies, 2020)

Updating user views:

After the order has been confirmed and settled by the brokerage firm, the brokerage send the details of the confirmed order back to Sharesies. The transaction information travels from the brokerage to the automated nominee server for instructions on where to be sent, then through the internal network to the AWS storage, where transaction information is stored. This updated data in AWS gets updated (likely very frequently) and shows on the users account.

End-to-end data communications:

TCP/IP is used to send data reliably to the correct destination - such as servers, third parties, or user devices. TCP/IP combined with encryption protocols allows Sharesies to share important information with necessary entities in a safe, reliable manner, which is crucial in financial systems that handle sensitive information.

HTTP is used in conjunction with TLS to encrypt communications between users' devices and the Sharesies platform, effectively creating a HTTPS connection. This ensures sensitive data is protected from eavesdropping or interception while being transmitted over the internet.



Figure 2: Network POST request utilizing IAM API from AWS

Investigating network traffic on the Sharesies website, *Figure 2* indicates Sharesies uses Identity Access Management (IAM) Application Programming Interface (API) from AWS. This API allows Sharesies to securely control access to AWS resources, by specifying what users are authenticated and authorized to access certain resources (AWS, 2024). Since Sharesies also need channels to share data with third-party brokers, it's assumed that they utilize API's to communicate with these brokers. For example, DriveWealth provides an API for their customers (Sharesies) to utilize on their platform (DriveWealth, 2024).

What protocols are used?

Transport Layer Security (TLS) with Advanced Encryption Standard-256 (AES-256) is stated to be used by Sharesies to protect sensitive information during web communications (Sharesies Help, 2024). Sharesies uses TLS for encryption of data used on top of TCP/IP. This protocol is used in any web communications between

servers, users, and the platform. This is an important protocol to use with end-to-end communication over the internet, as it aims to provide privacy, integrity, and reliability of data transmission between the platform and devices, as stated by (Ivanov & Ruzhentsev, 2018).

Network Time Protocol (NTP) would be used as it is crucial for keeping integrity of transactions, upkeeping with compliance and regulations, and synchronizing systems within the network. Accurate timekeeping is vital for financial platforms as it ensures preventing transactional discrepancies, allows for accurate log monitoring and diagnostics of systems, ensuring compliance and regulatory requirements, explained by Safran (Safran, 2024).

Domain Name System (DNS) protocol is also used, which allows the platform to map user-friendly domain names to the IP addresses of its servers. This enables users to quickly and easily access Sharesies' resources, such as its web platform and services. Furthermore, DNS helps redirect users to resources hosted on external sources (such as AWS cloud services or payment pages) for efficient and reliable access.

Recommendations:

Investigating traffic through the application Wireshark, I have found that Sharesies utilizes TLS 1.2. Upgrading to TLS 1.3 will reduce communication times, remove previous security vulnerabilities, and increase user experience by reducing loading times. Although TLS 1.3 eliminates previous version issues, there are still considerations to keep in mind when implementing, explained in this paper by Ivanov and Ruzhentsev (Ivanov & Ruzhentsev, 2018) and documentation by IBM (IBM, 2024).

Sharesies would benefit from implementing a monthly or weekly campaign through their platform to update users on attacks targeted at users, such as scam texts or phishing emails. Supporting these campaigns with visual aids or quizzes to identify and test what an impersonated email or text message looks like would benefit their users on identifying these attacks. It was concluded in this paper on phishing that quizzes on phishing “has a perceived and actual social benefit. It’s bound to help in terms of raising general awareness” (Harley & Lee, 2007).

While Sharesies likely already has some form of event logging in their systems, revisiting and enhancing the system by implementing a robust and updated Security Information and Event Management (SIEM) solution could improve the effectiveness of threat detection and response. Hiring dedicated cybersecurity professionals to monitor logs in real-time would further strengthen security and ensure proactive responses to potential threats. This recommendation is supported in this report on ‘Enhancing Cloud SIEM for Banks’ (Turpu, 2021), which still applies to Sharesies as they handle the same sensitive data that banks do.

Conclusion

In conclusion, Sharesies utilizes common industry end-to-end communication methods, such as TCP/IP, HTTPS, and RESTful API's, while utilizing TLS protocol with AES-256 encryption methods to secure their communication lines. They use established systems such as AWS IAM to manage resource access. It's likely that timekeeping methods like NTP are implemented to ensure times are synchronized over the network, preventing mismatching or duplicate transactions. I recommended to implement informative or quiz campaigns to educate users, updating their encryption method to remove previous vulnerabilities, and reviewing their logging system to proactively respond to real-time threats.

References

AWS. (2024, 07 24). *What is IAM?* Retrieved from AWS Docs: https://docs.aws.amazon.com/IAM/latest/UserGuide/introduction.html

Bernstein, P. A., & Newcomer, E. (2009). *Chapter 3 - Transaction Processing Application Architecture.* Retrieved from ScienceDirect: https://www.sciencedirect.com/science/article/abs/pii/B9781558606234000032

DriveWealth. (2024, 05 24). *API Introduction*. Retrieved from DriveWealth Developer: https://developer.drivewealth.com/apis/reference/introduction

Harley, D., & Lee, A. (2007). *PHISH PHODDER: IS USER EDUCATION HELPING OR HINDERING?* Retrieved from Citeseer: https://citeseerx.ist.psu.edu/document?repid=rep1&type=pdf&doi=2f61134e6f56bafb496d3c3e2f355ae8e9d1704d

IBM. (2024, 12 02). *Compatibility risks and known issues*. Retrieved from IBM SDK, Java Technology Edition: https://www.ibm.com/docs/en/sdk-java-technology/8?topic=handshake-compatibility-risks-known-issues

Ivanov, O., & Ruzhentsev, V. (2018). *Comparison of Modern Network Attacks on TLS Protocol.* Retrieved from sci-hub: https://sci-hub.se/https://ieeexplore.ieee.org/document/8632026

Safran. (2024, 09 20). *The Significance of Accurate Timekeeping and Synchronization in Trading Systems*. Retrieved from White Papers. Safran: https://safran-navigation-timing.com/timekeeping-and-synchronization-in-trading-systems/

Sharesies. (2020, 09 30). *Behind the scenes: Sharesies' process for US investments.* Retrieved from Sharesies: https://www.sharesies.nz/learn/behind-the-scenes-sharesies-process-for-us-investments

Sharesies Help. (2024, 09 23). *Security and internet saftey.* Retrieved from Intercom: https://intercom.help/sharesies/en/articles/2348225-security-and-internet-safety

Turpu, R. R. (2021, 07). *ENHANCING CLOUD SECURITY INFORMATION AND EVENT MANAGEMENT (SIEM) FOR BANKS*. Retrieved from researchgate: https://www.researchgate.net/publication/378152115_ENHANCING_CLOUD_SECURITY_INFORMATION_AND_EVENT_MANAGEMENT_SIEM_FOR_BANKS